

CLAWSCAN

SECURITY WHITE PAPER

The State of MCP Security -- February 2026

THE CRISIS

The Model Context Protocol is everywhere. And it is dangerously insecure.

180,000+

Active Deployments

Growing 40% monthly

512

Vulnerabilities Found

8 rated **CRITICAL**

21,639

Exposed Instances

Publicly accessible

135,000+

GitHub Stars

341

Malicious Skills

12% of ClawHub

1.5M

API Tokens Leaked

Moltbook breach

"MCP represents one of the most significant attack surface expansions in enterprise AI infrastructure."

-- Cisco Talos Intelligence, Jan 2026

"The speed of MCP adoption has far outpaced security tooling. Most deployments are running blind."

-- Kaspersky GReAT, Feb 2026

WHAT IS HAPPENING RIGHT NOW:

CVE-2026-25253:

One-click remote code execution via MCP tool invocation (CVSS 8.8)

ClawHavoc Framework:

Nation-state exploit toolkit targeting MCP deployments in the wild

Moltbook Breach:

35,000 emails + 1.5M API tokens exposed from MCP-connected platform

China CNCERT Warning:

Formal government advisory issued against MCP security risks

Shadow MCP Servers:

Developers spinning up unaudited instances -- no IT visibility

"The vulnerability discovery rate in MCP implementations suggests systemic security design flaws that cannot be patched individually -- they require a fundamentally new approach to AI infrastructure security."

-- Reuters Technology Analysis, Feb 2026

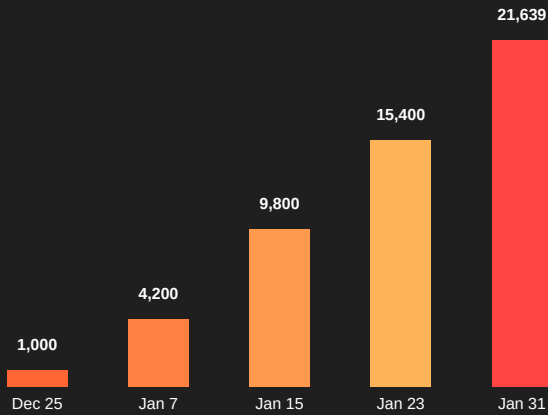
Every unsecured MCP server is a door left wide open.

Most organizations don't even know the door exists.

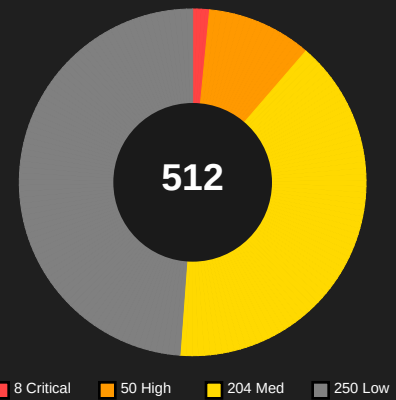
THE THREAT LANDSCAPE

Data-driven analysis of the MCP security crisis

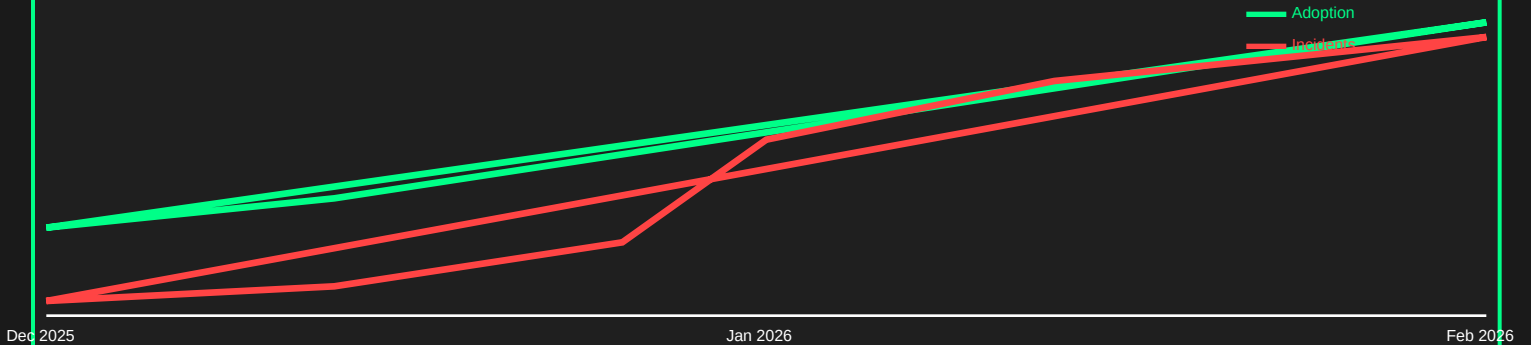
EXPOSED INSTANCES GROWTH



512 VULNERABILITIES



ADOPTION vs SECURITY INCIDENTS



CRITICAL: CVE-2026-25253

VULNERABILITY DETAILS

- Type: Remote Code Execution (RCE)
- CVSS Score: 8.8 (HIGH)
- Vector: MCP tool invocation
- Attack: Single malicious tool call
- Impact: Full system compromise
- Auth Required: None
- Status: Actively exploited in the wild

CLAWHAVOC EXPLOIT FRAMEWORK

- First MCP-specific attack toolkit
- Combines prompt injection + tool abuse
- Automated scanning for exposed instances
- Credential harvesting from MCP sessions
- Lateral movement through connected tools
- Attributed to nation-state actors
- Active campaigns detected since Jan 2026

35,000

Emails Exposed
Moltbook Breach

12%

Skills Are Malicious
341 of 2,857 on ClawHub

0

Security Tools Existed
Before ClawScan

The question is not IF your MCP deployment will be targeted -- it is WHEN.

THE 7-LAYER ATTACK SURFACE

Why traditional security tools cannot protect MCP deployments

LAYER 7: SUPPLY CHAIN

Malicious skills, poisoned models

LAYER 6: DATA EXFILTRATION

Prompt injection, context leaks

LAYER 5: TOOL ABUSE

Unrestricted tool access, RCE

LAYER 4: AUTHENTICATION

Weak/missing auth, token theft

LAYER 3: NETWORK EXPOSURE

Open ports, unencrypted traffic

LAYER 2: CONFIGURATION

Default settings, permissive CORS

LAYER 1: RUNTIME

Container escapes, resource abuse

WHY TRADITIONAL TOOLS FAIL

TRADITIONAL SECURITY

- x Network scanners miss AI-specific risks
- x SAST/DAST blind to prompt injection
- x No awareness of tool permission models
- x Cannot detect malicious skill payloads
- x Ignore MCP-specific authentication gaps
- x No supply chain analysis for AI tools
- x Zero coverage of data exfiltration via LLM
- x Miss shadow MCP server deployments
- x Cannot grade overall MCP posture

CLAWSCAN APPROACH

- + Purpose-built for MCP protocol analysis
- + 24 checks across all 7 attack layers
- + Prompt injection detection built-in
- + Tool permission and allowlist validation
- + ClawHub skill supply chain scanning
- + MCP authentication and TLS verification
- + Data exfiltration pathway analysis
- + Shadow server discovery on your network
- + A-F grading with actionable remediation

THE SECURITY GAP

Every major security framework -- NIST, OWASP, MITRE ATT&CK -- is now racing to add MCP-specific guidance. But frameworks don't stop attacks. Tools do. Until ClawScan, there was no tool purpose-built for MCP security. Organizations were flying blind, deploying AI agents with full system access and zero security validation.

0

MCP auditing tools
before ClawScan

7

Distinct attack layers
require specialized checks

24

Security checks across
all 7 layers

CLAWSCAN: THE SOLUTION

The first dedicated security auditing tool for MCP deployments

SCAN

24 automated security checks in seconds.
Pure bash. Zero deps.
Works everywhere.

GRADE

A-F letter grades with percentage scores.
Instant posture assessment.

FIX

Actionable remediation for every finding.
Prioritized by risk.
Copy-paste fixes.

5 SECURITY CATEGORIES

Transport
Security

Authentication

Input
Validation

Tool
Governance

Logging &
Monitoring

REAL SCAN OUTPUT

```
$ clawscan --full-audit
ClawScan v1.0 -- MCP Security Auditor
=====
[PASS] TLS encryption enabled
[PASS] Authentication required
[PASS] Input validation active
[PASS] Tool allowlisting configured
[FAIL] Rate limiting not configured
[FAIL] Audit logging disabled
[PASS] No known CVEs detected
[PASS] Container isolation verified
=====
GRADE: B | SCORE: 95/130 (73%)
Passed: 18/24 | Failed: 6/24
=====
```

BEFORE CLAWSCAN

F

Unknown Risk
0/24 checks



AFTER CLAWSCAN

B

73% Secure
18/24 passed

GET STARTED

COMMUNITY

Free

CLI scanner
24 checks
A-F grading

PRO

\$29/mo

CI/CD integration
Scheduled scans
Slack alerts

ENTERPRISE

Custom

API access
Compliance reports
Dedicated support

Start securing your MCP deployment today.

clawscan.app